

Clase 215 — Playbooks de respuesta a incidentes

Parte: **9 — Forense digital y respuesta a incidentes** · Fuente: *Roberts & Brown — Intelligence-Driven Incident Response* y NIST SP 800-61  Duración estimada: **110 min** · Nivel: **Intermedio**

Objetivo

Aprender a diseñar **playbooks** de respuesta: procedimientos estructurados y repetibles que guían al equipo paso a paso ante tipos concretos de incidente (phishing, ransomware, cuenta comprometida, malware). Al terminar podrás escribir playbooks accionables e integrarlos con automatización (SOAR).

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Estructurar** un playbook con fases, roles y puntos de decisión.
2. **Escribir** playbooks para incidentes comunes.
3. **Integrar** inteligencia de amenazas y ATT&CK en el playbook.
4. **Definir** criterios de escalado y de decisión.
5. **Automatizar** pasos repetibles con SOAR.

Temas

#	Tema	Por qué importa
1	Qué es un playbook	Respuesta consistente
2	Anatomía: fases, roles, decisiones	Estructura reutilizable
3	Playbook de phishing	El caso más frecuente
4	Playbook de ransomware	El más dañino
5	Playbook de cuenta comprometida	Muy común en nube
6	Integración con ATT&CK	Mapear al adversario
7	SOAR y automatización	Escalar la respuesta
8	Mantenimiento del playbook	No dejar que caduque

Definiciones y características

- **Playbook:** procedimiento estructurado para un tipo de incidente. Característica: repetible y accionable, no un ensayo teórico.
- **Runbook:** pasos técnicos detallados de una tarea concreta dentro del playbook. Característica: más granular.

- **Punto de decisión:** bifurcación con criterio explícito (p. ej. "¿hay cifrado activo? → sí/no"). Característica: evita improvisar bajo presión.
- **Escalado:** paso a un nivel superior (líder, legal, dirección). Característica: se dispara por criterios definidos.
- **SOAR:** Security Orchestration, Automation and Response. Característica: automatiza tareas repetibles del playbook.
- **IOC:** indicador de compromiso (hash, IP, dominio). Característica: alimenta el bloqueo y la búsqueda retroactiva.
- **ATT&CK:** matriz de tácticas/técnicas del adversario. Característica: da un lenguaje común para describir el ataque.

Herramientas y preparación

- **Documentación:** plantilla de playbook (fases PICERL), diagramas de flujo.
- **SOAR/casos:** TheHive + Cortex (gratuitos), o Shuffle para automatización.
- **Inteligencia:** MITRE ATT&CK Navigator, MISP para IOCs.
- **Ejercicio aplicado:** no requiere entorno ofensivo; es diseño de proceso.

Laboratorio guiado

Ejercicio aplicado de diseño de proceso.

1. Elige un tipo de incidente (empieza por **phishing**) y define su alcance y disparadores.
2. Estructura el playbook por fases PICERL. Para **detección/identificación**, define: - Fuentes de alerta (reporte de usuario, gateway de correo, EDR). - Cómo validar que es phishing real.
3. Para **contención**, escribe pasos concretos: - Aislar el buzón, bloquear el remitente/dominio, buscar quién más lo recibió (búsqueda retroactiva por IOC).
4. Añade **puntos de decisión** con criterio: "¿el usuario hizo clic? → sí: revisar credenciales y sesión; no: cerrar".
5. Mapea cada paso a técnicas **ATT&CK** (p. ej. Phishing T1566) para dar contexto.
6. Define **criterios de escalado** (¿varias víctimas? ¿ejecutivo afectado? → escalar a líder y legal).
7. Marca los pasos **automatizables** con SOAR (extraer IOCs, bloquear en el gateway, notificar).
8. Cierra con **criterios de resolución** y captura de lecciones aprendidas.

Ejercicios

1. Escribe la fase de contención de un playbook de ransomware.
2. Define cinco puntos de decisión para una cuenta comprometida.
3. Mapea un playbook de malware a tres técnicas ATT&CK.
4. Diseña los criterios de escalado a legal y dirección.
5. Identifica qué tres pasos automatizarías con SOAR y por qué.
6. Crea un diagrama de flujo del playbook de phishing.

Reto verificable

Diseña un playbook completo para "cuenta de correo corporativa comprometida" con las seis fases PICERL, al menos cuatro puntos de decisión, mapeo a ATT&CK, criterios de escalado y tres pasos marcados como automatizables.

Criterio de aceptación: el playbook es ejecutable por otra persona sin ayuda, cada fase tiene pasos numerados con responsable, los puntos de decisión tienen criterio explícito, y hay al menos tres técnicas ATT&CK referenciadas.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El playbook es teoría, no acción	Faltan pasos concretos. Escribe comandos/acciones verificables.
Nadie sabe cuándo escalar	Sin criterios de escalado. Defínelos por adelantado.
Puntos de decisión ambiguos	Criterio subjetivo. Hazlos binarios y objetivos.
Playbook desactualizado	Sin mantenimiento. Revísalo tras cada incidente.
Todo manual, sin escala	No identificaste tareas automatizables. Marca las repetibles para SOAR.

Preguntas frecuentes

¿Playbook o runbook? El playbook orquesta la respuesta a un tipo de incidente; el runbook detalla una tarea técnica dentro de él.

¿Cuántos playbooks necesito? Empieza por los incidentes más frecuentes y dañinos: phishing, ransomware, cuenta comprometida, malware. Amplía según tu contexto.

¿SOAR reemplaza al analista? No. Automatiza lo repetible (enriquecer IOCs, bloquear, notificar) para que el analista se enfoque en decisiones.

¿Cómo evito que caduquen? Revísalos tras cada incidente y en las lecciones aprendidas; un playbook es un documento vivo.

Referencias

- Roberts & Brown — *Intelligence-Driven Incident Response*, O'Reilly 2017.
- NIST SP 800-61 Rev. 2: <https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final>
- MITRE ATT&CK: <https://attack.mitre.org/>
- TheHive & Cortex: <https://thehive-project.org/>

Siguiente clase

Clase 216 - Contencion, erradicacion y recuperacion